

1. Dependency Security
2. Supply Chain Attack
3. How to handle Dependency Security in different programming languages

Dependency Security

Dependency Security is the practice of identifying, monitoring, and updating third-party libraries to protect your application from known vulnerabilities and malicious packages.



Supply Chain Attack

A Supply Chain Attack occurs when an attacker compromises a third-party dependency, causing applications that trust that dependency to become compromised.



How to handle Dependency Security in different programming languages

1. Node

a. npm audit

It generates report if there is any vulnerability

Output:

8 vulnerabilities (1 low, 1 moderate, 6 high)

b. npm audit fix

c. npm audit fix --force

If you use these command, it may break your existing flow.

Try not to use these command.

Try to fix it manually

d. npm outdated

It'll give a report, if there is any outdated dependency

e. Snyk

Snyk continuously scans your project for vulnerabilities and suggests fixes.

f. GitHub dependabot

Dependabot automatically checks dependencies for updates and creates pull requests to help keep them secure and up to date.

2. Java

Package Manager: Mavan, Gradle

Security Tool: OWASP Dependency check, Synk, GitHub Dependabot

3. Python

Package Manager: PIP

Security Tool: pip-audit, Saftey, Synk, GitHub Dependabot

4. Rust

Package Manager: Cargo

Security Tool: cargo audit, Synk, GitHub Dependabot

